



DOCUMENTACIÓN TÉCNICA Y OPERATIVA

Proyecto Web Dadunex y Panel Administrativo

Etapa 1 - Presencia digital y gestión de contactos comerciales

ESTADO DE LA ETAPA

COMPLETADA Y OPERATIVA

Cierre funcional con deuda técnica documentada

Documento	Valor
Organización	Agrícola e Inversiones Dadunex Limitada
Responsable técnico	C3 Cloud
Versión	1.0
Fecha de cierre	17 de agosto de 2026
Línea base de código	Rama main - commit d0fb80d
Clasificación	Uso interno - no contiene contraseñas ni claves secretas

1. Control y propósito del documento

Este documento consolida la arquitectura, el alcance funcional, la operación, la seguridad, el despliegue y los criterios de cierre del sitio corporativo Dadunex y su panel administrativo. Fue elaborado a partir del código fuente adjunto, el historial Git, la configuración visible de los clientes y las verificaciones realizadas sobre la publicación vigente.

1.1 Alcance documental

- Sitio público dadunex.cl, incluida la página principal, la política de privacidad, la página 404, los activos visuales, el SEO técnico y el formulario de contacto.
- Backend del formulario público basado en API Gateway, Lambda, DynamoDB, Amazon SES y CloudWatch.
- Panel administrativo estático, autenticación con Amazon Cognito y gestión de contactos mediante una API protegida.
- Infraestructura AWS, automatización de despliegues, variables de configuración, operación, soporte y continuidad.
- Criterios que permiten declarar cerrada la etapa y registro de deuda técnica que no impide la operación actual.

1.2 Fuentes revisadas

Fuente	Cobertura	Resultado
ZIP del proyecto	HTML, CSS, JavaScript, Lambda, dependencias, documentación y Git	Revisado íntegramente, excluyendo dependencias de terceros del análisis funcional
Historial Git	Evolución hasta el 17-08-2026	Última línea base: d0fb80d
Publicación	dadunex.cl, privacidad.html y robots.txt	HTTP 200 mediante CloudFront/S3
Validaciones locales	Sintaxis JavaScript, importación Lambda y preflight OPTIONS	Correctas
Pruebas funcionales previas	Registro, notificación, actualización y eliminación de contactos	Confirmadas durante la construcción del proyecto

Definición de cierre

La etapa se considera completada operativamente porque el sitio publicado coincide con la línea base, el flujo comercial funciona y el panel cubre el ciclo de gestión de contactos. La reproducibilidad total de la infraestructura y el endurecimiento de seguridad quedan como trabajo de mantenimiento, no como nuevas funciones del alcance.

Contenido

- 1. Control y propósito del documento** 2
 - 1.1 Alcance documental 2
 - 1.2 Fuentes revisadas 2
- 2. Resumen ejecutivo** 5
 - 2.1 Resultado alcanzado 5
 - 2.2 Límites de esta etapa 5
- 3. Alcance funcional y actores** 6
 - 3.1 Objetivos de negocio 6
 - 3.2 Actores y responsabilidades 6
 - 3.3 Casos de uso completados 6
- 4. Arquitectura de la solución** 7
 - 4.1 Separación lógica 7
- 5. Sitio web público** 8
 - 5.1 Estructura visible 8
 - 5.2 Experiencia, accesibilidad y rendimiento 8
 - 5.3 SEO técnico implementado 8
- 6. Formulario y backend de contacto** 9
 - 6.1 Contrato de entrada 9
 - 6.2 Controles aplicados 9
 - 6.3 Respuestas principales 10
- 7. Modelo de datos y ciclo de vida** 10
 - 7.1 Tabla de contactos 10
 - 7.2 Estados 10
 - 7.3 Retención y eliminación 10
- 8. Panel administrativo** 11
 - 8.1 Módulos implementados 11
 - 8.2 Flujo de uso recomendado 11
 - 8.3 Comportamiento técnico 11
- 9. Autenticación, autorización y API administrativa** 12
 - 9.1 Amazon Cognito 12
 - 9.2 Endpoints consumidos 12
 - 9.3 Controles de autorización 12
- 10. Infraestructura AWS** 13
 - 10.1 Inventario lógico 13
 - 10.2 Endpoints visibles en la línea base 13
 - 10.3 Diseño de costos 13
- 11. Configuración y variables** 14
 - 11.1 Lambda del formulario 14
 - 11.2 Frontend administrativo 14

11.3 Secretos de despliegue GitHub	14
12. Despliegue y control de versiones	15
12.1 Flujo automatizado del sitio	15
12.2 Flujo automatizado del panel	15
12.3 Componentes no automatizados	15
12.4 Procedimiento de release	15
12.5 Rollback	15
13. Manual de operación	16
13.1 Rutina diaria del usuario	16
13.2 Rutina mensual técnica	16
13.3 Diagnóstico rápido	16
14. Seguridad y privacidad	17
14.1 Controles presentes	17
14.2 Riesgos residuales priorizados	17
14.3 Principio de mínimo privilegio	17
15. Respaldo, recuperación y continuidad	18
15.1 Objetivos	18
15.2 Escenarios	18
15.3 RPO/RTO sugeridos para esta etapa	18
16. Verificación y criterios de aceptación	19
16.1 Evidencia obtenida el 17-08-2026	19
16.2 Matriz de cierre	19
17. Plan de mantenimiento posterior al cierre	20
17.1 Evoluciones que pertenecen a una nueva etapa	20
18. Anexos técnicos	21
18.1 Estructura relevante del repositorio	21
18.2 Métricas de la línea base	21
18.3 Identificadores y secretos	21
18.4 Glosario	22

2. Resumen ejecutivo

Dadunex dispone de una solución serverless y de bajo costo operativo que cubre dos necesidades: presentar la empresa y sus productos a compradores B2B, y recibir y administrar solicitudes comerciales sin depender de un servidor permanente. El sitio está orientado a productores, distribuidores, exportadoras, supermercados y compradores mayoristas de damascos, duraznos, nectarines y ciruelas.

2.1 Resultado alcanzado

Componente	Resultado actual	Estado
Sitio corporativo	Landing responsive, identidad Dadunex, productos, certificaciones, contacto, privacidad y 404	Completo
Captura de oportunidades	Validación de formulario, registro persistente, control de abuso y notificación por correo	Completo
Panel administrativo	Login, dashboard, listado, búsqueda, filtros, estados, notas, detalle y eliminación	Completo
Autenticación	Amazon Cognito con JWT, cambio de contraseña temporal y soporte MFA	Completo
Despliegue	Publicación separada para web y admin mediante GitHub Actions, S3 y CloudFront	Completo
Observabilidad	Logs de Lambda y estados de envío almacenados	Operativo
Infraestructura como código	No existe plantilla SAM/CloudFormation en el repositorio	Pendiente de mantenimiento

2.2 Límites de esta etapa

- No incluye Agroplan, gestión agrícola, inventario, productos fitosanitarios, reportes productivos ni multiempresa.
- No incluye CRM completo, campañas de marketing automatizadas ni analítica activa; Google Tag Manager permanece comentado.
- No incluye administración de usuarios, roles o permisos desde la interfaz. Los usuarios se administran actualmente en Cognito.
- No incluye edición de contenido del sitio desde el panel; los cambios se realizan en el repositorio y se despliegan.

Conclusión ejecutiva

La plataforma está apta para su objetivo actual: presencia corporativa, captación B2B y gestión centralizada de contactos. La siguiente etapa debe tratarse como evolución independiente y no como requisito pendiente de este cierre.

3. Alcance funcional y actores

3.1 Objetivos de negocio

- Fortalecer la presencia digital de Dadunex y transmitir experiencia, calidad y confianza.
- Presentar la oferta de carozos: damascos, duraznos, nectarines y ciruelas.
- Comunicar certificaciones Global G.A.P. y GRASP.
- Captar consultas de compradores y conservarlas incluso si falla el envío de correo.
- Dar al personal autorizado una vista única para atender, clasificar y eliminar contactos.

3.2 Actores y responsabilidades

Actor	Interacción	Responsabilidad
Visitante o comprador	Navega y envía formulario	Entregar información válida y utilizar el canal para consultas comerciales
Encargado de ventas/producción	Ingresa al panel y gestiona contactos	Revisar, responder, actualizar estado, registrar notas y eliminar cuando corresponda
Administrador AWS	Mantiene servicios, variables, permisos y costos	Disponibilidad, seguridad, respaldos y monitoreo
Desarrollador	Modifica código y despliega	Control de versiones, pruebas, documentación y rollback
Cognito	Autentica al usuario del panel	Emitir y validar tokens según configuración del User Pool

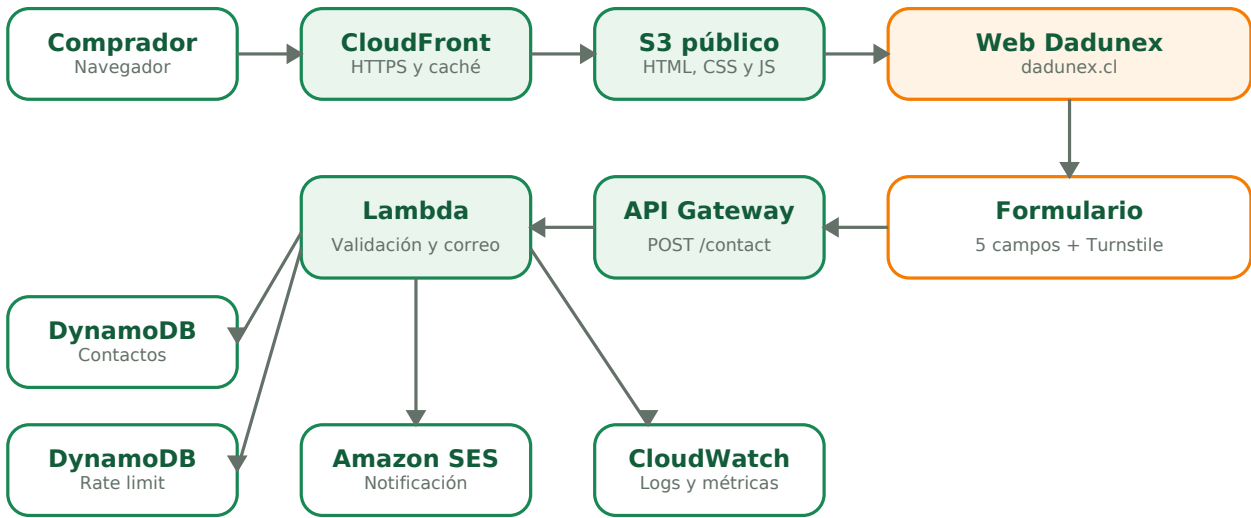
3.3 Casos de uso completados

ID	Caso de uso	Resultado
CU-W01	Consultar información corporativa	El visitante accede a empresa, especies y certificaciones
CU-W02	Enviar una consulta	El sistema valida, registra y notifica
CU-A01	Autenticar usuario	Cognito entrega sesión válida o informa el error
CU-A02	Consultar dashboard	Muestra totales por estado y contactos recientes
CU-A03	Buscar y filtrar contactos	Búsqueda por identidad/asunto, filtro y orden local
CU-A04	Gestionar un contacto	Detalle, estado y notas
CU-A05	Eliminar datos	Eliminación permanente mediante API protegida
CU-A06	Verificar configuración	Pantalla de ajustes comprueba sesión, Cognito, región y API

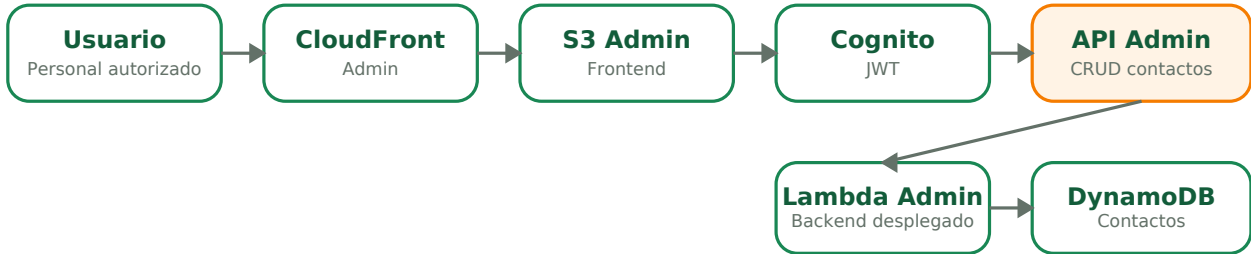
4. Arquitectura de la solución

La arquitectura separa el canal público del administrativo, pero ambos convergen en el ciclo de contactos. Los frontends son estáticos y los procesos con estado se resuelven con servicios administrados de AWS.

Canal público



Canal administrativo



Principio	Aplicación en el proyecto
Serverless	No hay EC2, balanceador ni base de datos relacional permanente
Separación de canales	Web y panel usan buckets, distribuciones y flujos de despliegue distintos
Persistencia antes del correo	La consulta se guarda antes de invocar SES para evitar pérdida de oportunidades
Autenticación administrada	Cognito evita almacenar contraseñas en el proyecto
Configuración externa	Correos, tablas y secretos se inyectan como variables de Lambda
Costo proporcional	S3, CloudFront, Lambda, API Gateway y DynamoDB cobran principalmente por uso

4.1 Separación lógica

- La web pública solo acepta envíos del formulario y no conoce credenciales administrativas.
- El panel usa un endpoint administrativo distinto y adjunta un ID Token en el encabezado Authorization.
- La autenticación ocurre en Cognito; la autorización efectiva debe mantenerse también en API Gateway/Lambda.

5. Sitio web público

5.1 Estructura visible

Sección	Contenido	Propósito
Inicio	Hero e introducción	Presentar la marca y conducir a contacto
Nosotros	Empresa familiar y experiencia	Generar confianza
Productos	Damascos, duraznos, nectarines y ciruelas	Comunicar oferta
Certificaciones	Global G.A.P. y GRASP	Respaldar calidad y cumplimiento
Contacto	Nombre, correo, teléfono, asunto y mensaje	Captar oportunidades B2B
Privacidad	Finalidad, conservación, derechos y seguridad	Informar el tratamiento de datos
404	Mensaje y retorno al inicio	Recuperar navegación ante rutas inexistentes

5.2 Experiencia, accesibilidad y rendimiento

- Diseño responsive con Bootstrap 5.3 y estilos propios.
- Uso de etiquetas, mensajes de validación, estados ARIA, foco posterior al envío y textos alternativos.
- Imágenes principales en WebP, lazy loading en contenido secundario, dimensiones declaradas y preload del hero.
- Animaciones progresivas mediante IntersectionObserver y alternativa para navegadores sin soporte.
- Mensajes de éxito y error mediante SweetAlert2, con estado accesible adicional.

5.3 SEO técnico implementado

- Título y descripción orientados a producción de carozos en Chile.
- URL canonical, Open Graph, Twitter Card y datos estructurados Schema.org Organization.
- robots.txt, sitemap.xml, manifest e iconos para distintos dispositivos.
- Jerarquía semántica y atributos de idioma es-CL.
- Google Tag Manager y evento de conversión permanecen comentados; no forman parte del funcionamiento activo.

Hallazgo de calidad HTML

El archivo index.html tiene un cierre de div dentro de un comentario en la cabecera del formulario. Los navegadores lo recuperan y la publicación funciona, pero un validador estricto reporta desajuste de etiquetas. Debe corregirse como mantenimiento de prioridad alta.

6. Formulario y backend de contacto

El backend público está implementado en Node.js como una función Lambda. Valida la solicitud, limita el abuso, guarda el contacto en DynamoDB y luego envía la notificación mediante Amazon SES.



6.1 Contrato de entrada

Campo	Regla cliente	Regla servidor
name	Mínimo 4 caracteres, letras y signos permitidos	Obligatorio, limpiado, máximo 100 y mínimo 4
email	Formato básico	Obligatorio, minúsculas, máximo 254 y patrón de correo
phone	9 dígitos	Móvil chileno, admite 9XXXXXXX o +569XXXXXXX
subject	Mínimo 2	Obligatorio, sin saltos de cabecera, máximo 150
message	Mínimo 4	Obligatorio, máximo 2.000 y sin caracteres de control
turnstileToken	Obtenido del widget	Validado cuando TURNSTILE_ENABLED=true
website	No existe hoy en la vista	Honeypot soportado por Lambda

6.2 Controles aplicados

- Tamaño máximo del body: 15.000 caracteres antes de parsear JSON.
- CORS restringido a <https://dadunex.cl> y <https://www.dadunex.cl>.
- Cinco solicitudes por IP cada 15 minutos y cinco por correo cada 60 minutos.
- IP y correo se convierten a SHA-256 en la tabla de rate limit.
- Sanitización para HTML y eliminación de saltos en encabezados del correo.
- Encabezados no-store, nosniff, DENY, Referrer-Policy y Permissions-Policy en la respuesta API.
- No se registra el contenido del mensaje en CloudWatch; solo metadatos técnicos y errores.

6.3 Respuestas principales

HTTP	Situación	Comportamiento
200	Contacto procesado	Registro guardado y correo aceptado por SES
204	Preflight OPTIONS	Respuesta CORS sin body
400	Campos o JSON inválidos	Mensaje controlado
403	Origen o Turnstile rechazado	No se escribe ni se envía
405	Método distinto de POST/OPTIONS	Método no permitido
413	Body mayor al límite	Solicitud rechazada
429	Cuota excedida	Incluye Retry-After
500	Configuración o error interno	Mensaje genérico al cliente y detalle en logs
503	Servicio Turnstile no disponible	Invita a reintentar

7. Modelo de datos y ciclo de vida

7.1 Tabla de contactos

Grupo	Atributos	Uso
Identidad	contactId	UUID y clave principal
Fechas	createdAt, updatedAt, expiresAt	Auditoría y TTL a 24 meses
Datos comerciales	name, email, phone, subject, message	Gestión de la consulta
Flujo	status, responseDate, notes, source	Seguimiento en el panel
Correo	emailStatus, sesMessageld, emailError	Trazabilidad de SES
Metadatos	requestId, sourcelp, userAgent	Diagnóstico y auditoría técnica

7.2 Estados

Dominio	Valores	Transición
Estado comercial	NEW, PENDING, ANSWERED	El usuario autorizado cambia el estado desde el detalle
Estado de correo	PENDING, SENT, FAILED	Lambda inicia en PENDING y actualiza según respuesta de SES

7.3 Retención y eliminación

- La función calcula expiresAt a 24 meses desde la recepción, consistente con la política publicada.
- DynamoDB TTL elimina registros vencidos de forma asíncrona; no debe interpretarse como borrado instantáneo al segundo exacto.
- La eliminación manual del panel es permanente y se ejecuta mediante DELETE sobre el contacto seleccionado.
- La tabla de rate limit conserva contadores solo para control de abuso y utiliza TTL adicional.

Alineación de privacidad

El backend conserva sourceIp y userAgent, mientras la enumeración principal de la política destaca los cinco campos del formulario. Se recomienda informar expresamente estos datos técnicos o dejar de persistirlos en la tabla de contactos. Esta observación requiere revisión legal antes de modificar la política.

8. Panel administrativo

8.1 Módulos implementados

Módulo	Funciones
Login	Correo, contraseña, visualización de contraseña, errores controlados, contraseña temporal y MFA
Dashboard	Totales nuevo/pendiente/respondido/total y cinco contactos recientes
Contactos	Listado, búsqueda, filtros por estado, orden por fecha/nombre y paginación de cinco filas
Detalle	Datos del remitente, fecha, estado de correo, asunto, mensaje, estado comercial y notas
Eliminación	Confirmación explícita y borrado permanente del registro
Ajustes	Correo autenticado, sesión, región, estado de Cognito, ambiente y prueba de conexión API
Navegación	Sidebar desktop/mobile, contadores y cierre de sesión

8.2 Flujo de uso recomendado

- Ingresar con la cuenta corporativa asignada en Cognito.
- Revisar en el dashboard los contactos nuevos y pendientes.
- Abrir el contacto, responder por correo o teléfono y registrar una nota breve.
- Cambiar a PENDING si requiere seguimiento o a ANSWERED cuando se haya atendido.
- Eliminar solo cuando corresponda por solicitud del titular, vencimiento o decisión autorizada.
- Cerrar sesión al finalizar, especialmente en equipos compartidos.

8.3 Comportamiento técnico

- El dashboard y el listado obtienen la colección desde GET /contacts.
- La búsqueda, orden y paginación se realizan en el navegador; es adecuado para el volumen inicial.
- El detalle se carga con GET /contacts/{id}; PATCH actualiza status/notes y DELETE elimina.
- Ante HTTP 401 o 403, el cliente elimina la sesión local y redirige al login.
- Los tokens se almacenan en localStorage; la mitigación principal debe ser evitar XSS y aplicar una política CSP adecuada.

9. Autenticación, autorización y API administrativa

9.1 Amazon Cognito

Parámetro visible	Valor
Región	us-east-1
User Pool ID	us-east-1_jtK7vvfhQ
App Client ID	7gm0qnbtl7v0klu1rqvlfghesl
Almacenamiento cliente	dadunex_admin_session en localStorage
Tokens usados	Access Token e ID Token; la API recibe el ID Token como Bearer

Los identificadores de User Pool y App Client son configuración pública del cliente y no sustituyen credenciales. No deben confundirse con contraseñas, secretos del App Client o claves de AWS.

9.2 Endpoints consumidos

Método	Ruta	Uso	Respuesta esperada
GET	/contacts	Listar contactos	{ contacts: [...] }
GET	/contacts/{contactId}	Obtener detalle	{ contact: {...} }
PATCH	/contacts/{contactId}	Actualizar estado y notas	{ contact: {...} }
DELETE	/contacts/{contactId}	Eliminar contacto	204 o respuesta sin contenido

9.3 Controles de autorización

- El frontend exige una sesión autenticada para acceder a las vistas, pero esto es solo una barrera de experiencia.
- La API debe validar la firma, expiración, issuer y audience del JWT en API Gateway o Lambda.
- Las operaciones PATCH y DELETE deben exigir autorización en servidor; ocultar botones no es suficiente.
- La respuesta 401/403 fuerza la salida del panel.

Trazabilidad del backend admin

El ZIP contiene el frontend y el contrato de consumo, pero no incluye el código fuente de la Lambda/API administrativa. El servicio está integrado y fue probado durante el proyecto; aun así, el código desplegado debe incorporarse al repositorio para que el sistema sea completamente reproducible y auditable.

10. Infraestructura AWS

10.1 Inventario lógico

Servicio	Responsabilidad	Configuración conocida
Amazon S3	Alojamiento estático	Bucket público dadunex.cl y bucket separado para admin; cifrado SSE-S3 observado
Amazon CloudFront	HTTPS, caché y entrega	Distribuciones separadas para web y admin
DNS/Dominio	Resolución de dadunex.cl	Dominio registrado en NIC Chile y zona administrada en AWS
API Gateway	Entrada a APIs	Endpoint público /default/contact y endpoint admin independiente
AWS Lambda	Lógica serverless	Formulario público y backend administrativo
DynamoDB	Contactos y rate limit	dadunex-prod-contacts en On-Demand y tabla de cuotas
Amazon SES	Notificación de contacto	Remitente configurado por variable de entorno
Amazon Cognito	Autenticación del panel	User Pool en us-east-1
CloudWatch	Logs y métricas	Registros de ejecución y errores de Lambda
GitHub Actions	Despliegue continuo	Dos workflows sobre rama main

10.2 Endpoints visibles en la línea base

Canal	Endpoint
Formulario público	https://02wbpx6ww4.execute-api.us-east-1.amazonaws.com/default/contact
API administrativa	https://h1hkv5eojk.execute-api.us-east-1.amazonaws.com
Sitio	https://dadunex.cl/

10.3 Diseño de costos

- DynamoDB en modo On-Demand evita capacidad reservada para un tráfico bajo e irregular.
- S3 y CloudFront sirven archivos estáticos sin mantener servidores encendidos.
- Lambda y API Gateway escalan por solicitud y no requieren EC2, ELB, NAT Gateway ni RDS.
- Los principales riesgos de costo son tráfico anómalo, retención indefinida de logs, invalidaciones excesivas y recursos de prueba olvidados.
- Se deben mantener Budgets/alertas, Cost Anomaly Detection y revisión mensual de recursos por región.

Estado de infraestructura como código

La documentación previa menciona AWS SAM, pero el repositorio adjunto no contiene template.yaml, CloudFormation ni Terraform. La infraestructura actual debe considerarse administrada desde consola/configuración externa hasta que se incorpore IaC.

11. Configuración y variables

11.1 Lambda del formulario

Variable	Obligatoria	Propósito
DESTINATION_EMAIL	Sí	Uno o más destinatarios, separados por coma
FROM_EMAIL	Sí	Remitente verificado en SES
CONTACTS_TABLE	Sí	Tabla principal de contactos
RATE_LIMIT_TABLE	Sí	Tabla de contadores y TTL
TURNSTILE_ENABLED	No	Activa validación server-side; valor por defecto false
TURNSTILE_SECRET_KEY	Condicional	Obligatoria si Turnstile está habilitado
AWS_REGION	Automática	Inyectada por Lambda

11.2 Frontend administrativo

Clave	Ubicación	Uso
API_BASE_URL	dadunex-admin/js/config.js	Base de la API protegida
COGNITO_REGION	dadunex-admin/js/config.js	Región del User Pool
COGNITO_USER_POOL_ID	dadunex-admin/js/config.js	Identificación del pool
COGNITO_CLIENT_ID	dadunex-admin/js/config.js	Aplicación pública del frontend

11.3 Secretos de despliegue GitHub

Workflow	Secretos requeridos
Web	AWS_ACCESS_KEY_ID, AWS_SECRET_ACCESS_KEY, AWS_REGION, S3_BUCKET, CLOUDFRONT_DISTRIBUTION_ID
Admin	AWS_ACCESS_KEY_ID, AWS_SECRET_ACCESS_KEY, AWS_REGION, ADMIN_S3_BUCKET, ADMIN_CLOUDFRONT_DISTRIBUTION_ID

Regla de seguridad	Nunca guardar TURNSTILE_SECRET_KEY, contraseñas, claves de AWS ni valores de sesión en el repositorio. Los identificadores públicos de Cognito y las URL de API sí pueden existir en el cliente, pero deben estar documentados y controlados.
---------------------------	---

12. Despliegue y control de versiones

12.1 Flujo automatizado del sitio

- Disparador: push a la rama main.
- Checkout y configuración de credenciales AWS.
- aws s3 sync del repositorio al bucket público con --delete.
- Exclusión de .git, .github, documentación, CSV, panel y Lambda.
- Invalidación completa /* de la distribución CloudFront pública.

12.2 Flujo automatizado del panel

- Disparador: cambios en dadunex-admin/** o en su workflow; también permite ejecución manual.
- Verificación previa de index.html, css y js.
- Sincronización únicamente de dadunex-admin/ al bucket administrativo.
- Invalidación completa de la distribución CloudFront del panel.

12.3 Componentes no automatizados

- El despliegue de Lambda pública no forma parte de GitHub Actions.
- El backend administrativo no está versionado en el ZIP.
- Las tablas, APIs, Cognito, SES, IAM, DNS y CloudFront no tienen plantilla IaC en esta línea base.

12.4 Procedimiento de release

Paso	Acción	Evidencia
1	Revisar git status y diff	Solo cambios esperados
2	Ejecutar node --check en JS y Lambda	Salida sin errores
3	Validar HTML, enlaces, responsive y formulario	Checklist de prueba
4	Commit descriptivo y push a main	Hash de commit
5	Revisar workflow	Ejecución verde
6	Comprobar HTTP 200 y contenido	Prueba postdespliegue
7	Enviar contacto de prueba controlado	Registro, correo y panel

12.5 Rollback

Para el frontend, revertir el commit defectuoso o volver a desplegar la revisión estable y luego invalidar CloudFront. Para Lambda, conservar el ZIP estable y utilizar versiones/alias. Para datos, no ejecutar rollback destructivo: restaurar desde exportación o backup según el incidente.

13. Manual de operación

13.1 Rutina diaria del usuario

Frecuencia	Actividad	Resultado esperado
Inicio de jornada	Abrir dashboard y revisar nuevos	Sin contactos críticos sin atender
Durante el día	Responder y cambiar estado/notas	Seguimiento actualizado
Cuando corresponda	Eliminar por solicitud o política	Dato removido de la vista y base
Fin de jornada	Cerrar sesión	Tokens locales eliminados

13.2 Rutina mensual técnica

- Revisar errores y duración de Lambda en CloudWatch.
- Revisar emailStatus FAILED y definir recuperación manual si existieran.
- Verificar TTL habilitado en ambas tablas y retención de logs.
- Revisar costos, anomalías y recursos activos en us-east-1.
- Validar certificados HTTPS, dominio, DNS y acceso al panel.
- Revisar dependencias CDN y AWS SDK; aplicar actualizaciones controladas.
- Exportar o respaldar configuración crítica y probar que existe una ruta de recuperación.

13.3 Diagnóstico rápido

Síntoma	Revisar	Acción
La web no carga	CloudFront, S3, DNS y certificado	Confirmar origen y última ejecución del workflow
El formulario no habilita	Campos válidos y token Turnstile	Recargar widget y revisar consola
HTTP 403 en formulario	Origin y validación Turnstile	Comprobar hostname, action y variable enabled
HTTP 429	Límite por IP/correo	Esperar Retry-After; no borrar la tabla salvo incidente
Registro existe pero no llegó correo	emailStatus y logs SES	Corregir SES y contactar desde el panel
Panel vuelve al login	Expiración/validez del JWT	Autenticar nuevamente y revisar authorizer
Panel no lista	GET /contacts y CORS	Usar Ajustes > Verificar conexión y revisar API
Cambio no se ve	Caché CloudFront	Confirmar invalidación y objeto S3

14. Seguridad y privacidad

14.1 Controles presentes

Capa	Control
Transporte	HTTPS mediante CloudFront
Identidad	Cognito, JWT, contraseña temporal y soporte MFA
API pública	CORS, límites, validación, sanitización, tamaño máximo y errores genéricos
Datos	SSE-S3 observado, DynamoDB administrado, TTL y acceso IAM
Correo	SES con Reply-To del remitente y contenido escapado
Operación	CloudWatch, estados SENT/FAILED y requestId
Privacidad	Aviso en formulario, política publicada y eliminación desde panel

14.2 Riesgos residuales priorizados

Prioridad	Riesgo	Tratamiento recomendado
Alta	HTML principal con cierre de etiqueta comentado	Corregir el bloque contact-heading y validar HTML
Alta	Turnstile exige action=contact_form en Lambda, pero el widget no declara data-action	Alinear frontend/backend y verificar TURNSTILE_ENABLED en producción
Alta	IP y userAgent almacenados sin enumeración expresa en la política	Revisar base legal, información y minimización
Alta	Código backend admin ausente del repositorio	Exportar la versión desplegada y versionarla
Media	Tokens en localStorage	Aplicar CSP estricta, evitar HTML inseguro y evaluar una arquitectura con cookies HttpOnly
Media	Claves AWS de larga duración en GitHub	Migrar a GitHub OIDC y rol de despliegue de privilegio mínimo
Media	CDN externos sin SRI/CSP documentada	Fijar versiones, añadir SRI donde aplique y cabeceras de seguridad en CloudFront
Media	Sin pruebas automatizadas reales	Agregar tests unitarios y de integración
Baja	node_modules y ZIP de despliegue dentro del repositorio	Separar artefactos de build y regenerarlos en CI

14.3 Principio de mínimo privilegio

- Lambda pública: PutItem y UpdateItem solo en contactos; UpdateItem solo en rate limit; SendEmail solo según identidad SES requerida.
- Lambda admin: Scan/GetItem/UpdateItem/DeleteItem únicamente en la tabla de contactos.
- Workflow web: escribir solo en el bucket público e invalidar solo su distribución.
- Workflow admin: escribir solo en el bucket admin e invalidar solo su distribución.
- Usuarios humanos: MFA y cuentas individuales; evitar credenciales compartidas.

Nota de cumplimiento

La política de privacidad incluida es una base operativa y hace referencia a la Ley 21.719. Este documento no reemplaza una revisión jurídica y no certifica cumplimiento legal; registra la correspondencia técnica observada y las brechas que deben revisarse.

15. Respaldo, recuperación y continuidad

15.1 Objetivos

Elemento	Estrategia mínima	Recuperación
Código	GitHub + ZIP de cierre	Checkout de commit estable
Frontend S3	Versionado del bucket recomendado	Restaurar objetos/versiones y revalidar CloudFront
Lambda pública	Código fuente + ZIP estable + versión Lambda	Publicar versión conocida y mover alias
API admin	Incorporar fuente e infraestructura	Redesplegar con contrato documentado
DynamoDB	PITR o backups/exportaciones según criticidad	Restaurar a tabla nueva y validar antes de conmutar
Cognito	Inventario de configuración y usuarios autorizados	Recrear pool/app client solo con procedimiento aprobado
DNS/CloudFront	Exportar configuración e identificar certificados	Restaurar rutas y orígenes

15.2 Escenarios

- Falla solo de correo: los contactos permanecen en DynamoDB con FAILED y pueden atenderse desde el panel.
- Falla de frontend: CloudFront puede seguir sirviendo caché; desplegar la revisión estable.
- Falla de API pública: suspender campañas de captación, revisar logs y comunicar canal alternativo.
- Eliminación accidental: recuperar desde backup si existe y si la restauración es compatible con la solicitud de privacidad.
- Compromiso de credenciales: revocar, rotar, revisar CloudTrail/logs y volver a desplegar con credenciales limpias.

15.3 RPO/RTO sugeridos para esta etapa

Componente	RPO sugerido	RTO sugerido
Web y panel estáticos	Último commit	4 horas
Configuración AWS	Último cambio documentado	8 horas
Contactos	24 horas si hay backup diario; menor con PITR	8 horas

Los objetivos anteriores son recomendaciones operativas para una empresa pequeña y deben ajustarse si el volumen o la dependencia comercial aumenta.

16. Verificación y criterios de aceptación

16.1 Evidencia obtenida el 17-08-2026

Prueba	Resultado	Evidencia
GET dadunex.cl	200 OK	CloudFront con origen Amazon S3
GET privacidad.html	200 OK	CloudFront con origen Amazon S3
GET robots.txt	200 OK	Archivo publicado y accesible
Paridad index.html	Coincide	SHA-256 local y publicado idénticos
Paridad privacidad.html	Coincide	SHA-256 local y publicado idénticos
Cifrado de objetos	Observado	x-amz-server-side-encryption: AES256
Sintaxis JS	Correcta	node --check en web, admin y Lambda
Lambda OPTIONS	204	Importación y ejecución local del handler
HTML estricto	Con observación	Desajuste en index.html, línea de contacto

16.2 Matriz de cierre

Criterio	Estado	Condición de aceptación
Sitio publicado	Cumple	Disponible por HTTPS y coincide con la línea base
Contenido corporativo	Cumple	Empresa, especies, certificaciones y contacto visibles
Formulario	Cumple	Valida, registra y notifica; control de abuso implementado
Panel	Cumple	Autentica y gestiona el ciclo completo del contacto
Privacidad	Cumple con observación	Aviso, política, TTL y eliminación; revisar metadatos técnicos
Despliegue	Cumple	Web y admin automatizados y separados
Operación	Cumple	Logs, estados y procedimiento de soporte disponibles
Reproducibilidad	Parcial	Falta IaC y código fuente de backend admin
Calidad automatizada	Parcial	Existen checks de sintaxis, no una suite de pruebas

Declaración de cierre

Se declara completada la Etapa 1: Web Dadunex y Panel Administrativo de Contactos. La solución está publicada, integrada y apta para operación. Los hallazgos abiertos se administran como deuda técnica del ciclo de mantenimiento y deben resolverse antes de una ampliación importante del sistema.

17. Plan de mantenimiento posterior al cierre

Orden	Acción	Prioridad	Esfuerzo	Criterio de terminado
1	Corregir cierre HTML del formulario	Alta	Bajo	Validador HTML sin error estructural
2	Alinear Turnstile data-action y flag productivo	Alta	Bajo	Prueba positiva y negativa server-side
3	Revisar IP/userAgent en privacidad y base	Alta	Medio	Decisión legal/técnica documentada
4	Versionar backend administrativo	Alta	Medio	Código, variables y despliegue reproducible
5	Migrar GitHub Actions a OIDC	Media	Medio	Sin claves AWS de larga duración
6	Agregar IaC	Media	Alto	Stack recreable en ambiente de prueba
7	Añadir pruebas automáticas	Media	Medio	Casos críticos ejecutados en CI
8	Configurar cabeceras CSP/HSTS y SRI	Media	Medio	Escaneo sin bloqueos funcionales
9	Optimizar repositorio y artefactos Lambda	Baja	Bajo	node_modules y ZIP fuera del control principal
10	Evaluar paginación server-side al crecer	Baja	Medio	API paginada antes de un volumen alto

17.1 Evoluciones que pertenecen a una nueva etapa

- Administración de usuarios, roles y permisos desde el panel.
- Edición de contenido corporativo y catálogo de productos.
- Analítica activa, medición de conversiones y panel comercial.
- Recordatorios, automatizaciones y seguimiento tipo CRM.
- Agroplan y los módulos agrícolas multiempresa.

Estas evoluciones deben estimarse y aprobarse como alcance nuevo. No afectan la aceptación de la etapa actual.

18. Anexos técnicos

18.1 Estructura relevante del repositorio

```
dadunexWeb/  
  index.html  
  privacidad.html  
  404.html  
  robots.txt  
  sitemap.xml  
  site.webmanifest  
  css/styles.css  
  js/script.js  
  images/  
  dadunex-admin/  
    index.html  
    dashboard.html  
    contacts.html  
    contact.html  
    settings.html  
    css/  
    js/  
  lambda/dadunex-contact-form/  
    index.mjs  
    package.json  
    package-lock.json  
  .github/workflows/  
    deploy.yml  
    deploy-admin.yml  
Documentacion_Dadunex/
```

18.2 Métricas de la línea base

Métrica	Valor
Código y estilos revisados	Aproximadamente 11.446 líneas, sin contar dependencias
Lambda pública	1.492 líneas; paquete dadunex-contact-form 1.1.0
Panel	5 vistas HTML, 8 scripts JS y 6 hojas CSS
Dependencias Lambda	AWS SDK v3: DynamoDB, Document Client y SES v2
Dependencias cliente	Bootstrap 5.3, SweetAlert2, Amazon Cognito Identity JS y Cloudflare Turnstile
Repositorio	https://github.com/lu1scanell0/dadunexWeb.git

18.3 Identificadores y secretos

Tipo	Puede estar en frontend	Debe ser secreto
URL API y región	Sí	No
Cognito User Pool ID / Client ID público	Sí	No
Turnstile site key	Sí	No
Turnstile secret key	No	Sí
AWS Access Key / Secret Key	No	Sí
Contraseñas y tokens de sesión	No deben versionarse	Sí
Correos operativos	Preferible configuración	Dato interno

18.4 Glosario

Término	Definición
CloudFront	Red de distribución de contenido de AWS
S3	Almacenamiento de objetos usado para los sitios estáticos
Lambda	Función ejecutada bajo demanda sin servidor permanente
API Gateway	Puerta de entrada HTTP para las funciones
DynamoDB	Base de datos NoSQL administrada
SES	Servicio de envío de correo de AWS
Cognito	Servicio de identidad y autenticación
JWT	Token firmado usado para acreditar una sesión
TTL	Marca de expiración para eliminación automática de registros
CORS	Reglas que controlan qué orígenes web pueden llamar una API
Turnstile	Control antiautomatización de Cloudflare
IaC	Infraestructura definida y versionada como código
RPO/RTO	Objetivos de pérdida máxima de datos y tiempo de recuperación

Fin del documento

Línea base documentada: main / d0fb80d. Cualquier cambio posterior debe actualizar versión, fecha, arquitectura, variables, endpoints, evidencias de prueba y registro de riesgos.